

**ĐẠI HỌC QUỐC GIA THÀNH PHỐ HỒ CHÍ MINH
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN
KHOA MẠNG MÁY TÍNH VÀ TRUYỀN THÔNG**

**Nguyễn Tài Phú - 23521185
Trần Minh Nhật - 23521099
Châu Hoàng Phúc - 23521191**

**ĐỒ ÁN MÔN HỌC
Lập trình kịch bản tự động hóa cho quản trị và bảo mật mạng**

Triển khai CIS Benchmark trên hệ thống Linux

Linux CIS Benchmark Implementation

**GIẢNG VIÊN HƯỚNG DẪN
Thạc sĩ Trần Thị Dung**

TP. HỒ CHÍ MINH, NĂM 2026

Mục lục

Mục lục	i
1 Tổng quan hệ thống	1
1.1 Tổng quan CIS	1
1.2 Tổng quan Linux	1
1.2.1 Manual Hardening	2
1.2.2 Automated Hardening	2
2 Phương pháp triển khai	13
2.1 Quy trình tổng thể	13
2.2 Phương pháp tiếp cận	13
2.2.1 Manual Configuration	13
2.2.2 Automation bằng Ansible	14
2.3 Mô hình triển khai	14
2.3.1 Quy trình triển khai	15
2.3.2 Mô hình triển khai Automated Security Hardening System	16
3 Triển khai	18
4 Tổng kết	19
4.1 Kết quả đạt được	19
4.2 Hạn chế	19
4.3 Hướng phát triển	19

Chương 1

Tổng quan hệ thống

1.1 Tổng quan CIS

CIS (Center for Internet Security) là tổ chức phi lợi nhuận phát triển các tiêu chuẩn bảo mật được công nhận rộng rãi trong ngành công nghệ thông tin. CIS Benchmarks cung cấp các hướng dẫn cấu hình chi tiết để bảo mật hệ thống theo best practices.

CIS Ubuntu Linux 24.04 LTS Benchmark v1.0.0 là tài liệu tham chiếu chứa 188 đề xuất cấu hình bảo mật cho Ubuntu Server 24.04 LTS. Các đề xuất được phân loại theo 7 nhóm chính và đánh giá theo 2 trạng thái:

- **Automated:** Các khuyến nghị có thể tự động hóa việc đánh giá và xác nhận trạng thái đạt/không đạt
- **Manual:** Các khuyến nghị yêu cầu các bước thủ công để xác thực vì trạng thái cấu hình có thể thay đổi tùy thuộc vào môi trường cụ thể

1.2 Tổng quan Linux

Ubuntu Server 24.04 LTS là phiên bản Long Term Support mới nhất, cung cấp nền tảng ổn định và an toàn cho môi trường production. Với kernel Linux 6.8 và các cải tiến bảo mật tích hợp, Ubuntu 24.04 LTS là lựa chọn lý tưởng cho triển khai các tiêu chuẩn bảo mật CIS.

Kiến trúc bảo mật Linux bao gồm nhiều lớp bảo vệ từ kernel level đến application level. Việc hardening hệ thống Linux đòi hỏi kiến thức sâu về:

- Kernel modules và filesystem security
- Network protocols và firewall configuration
- Access control và authentication mechanisms
- Logging và auditing systems
- System maintenance và file permissions

1.2.1 Manual Hardening

Phương pháp manual hardening đòi hỏi người quản trị thực hiện từng bước kiểm tra và cấu hình thủ công. Mặc dù tốn thời gian hơn, phương pháp này cung cấp sự linh hoạt cao và kiểm soát chi tiết.

STT	Tên khuyến nghị
1	Ensure unused filesystems kernel modules are not available
2	Ensure GPG keys are configured
3	Ensure package manager repositories are configured
4	Ensure updates, patches, and additional security software are installed
5	Ensure only approved services are listening on a network interface
6	Ensure IPv6 status is identified
7	Ensure ufw outbound connections are configured
8	Ensure iptables are flushed with nftables
9	Ensure nftables outbound and established connections are configured
10	Ensure iptables outbound and established connections are configured
11	Ensure ip6tables outbound and established connections are configured
12	Ensure password complexity is configured
13	Ensure minimum password days is configured
14	Ensure journald log file access is configured
15	Ensure journald log file rotation is configured
16	Ensure systemd-journal-upload authentication is configured
17	Ensure rsyslog logging is configured
18	Ensure rsyslog is configured to send logs to a remote log host
19	Ensure rsyslog is not configured to receive logs from a remote client
20	Ensure logrotate is configured
21	Ensure running and on disk configuration is same
22	Ensure SUID and SGID files are reviewed

Bảng 1.1: Danh sách các khuyến nghị CIS yêu cầu đánh giá thủ công

1.2.2 Automated Hardening

Phương pháp automation với Ansible cho phép thực hiện hàng loạt các kiểm tra và cấu hình bảo mật một cách tự động, nhất quán và có thể tái sử dụng. Ansible cung cấp các module mạnh mẽ để tương tác với hệ thống Linux.

STT	Tên khuyến nghị	Module
1	Ensure cramfs kernel module is not available	modprobe
2	Ensure freevxfs kernel module is not available	modprobe
3	Ensure hfs kernel module is not available	modprobe
4	Ensure hfsplus kernel module is not available	modprobe
5	Ensure jffs2 kernel module is not available	modprobe
6	Ensure overlayfs kernel module is not available	modprobe
7	Ensure squashfs kernel module is not available	modprobe
8	Ensure udf kernel module is not available	modprobe
9	Ensure usb-storage kernel module is not available	modprobe
10	Ensure /tmp is a separate partition	parted
11	Ensure nodev option set on /tmp partition	mount
12	Ensure nosuid option set on /tmp partition	mount
13	Ensure noexec option set on /tmp partition	mount
14	Ensure /dev/shm is a separate partition	parted
15	Ensure nodev option set on /dev/shm partition	mount
16	Ensure nosuid option set on /dev/shm partition	mount
17	Ensure noexec option set on /dev/shm partition	mount
18	Ensure separate partition exists for /home	parted
19	Ensure nodev option set on /home partition	mount
20	Ensure nosuid option set on /home partition	mount
21	Ensure separate partition exists for /var	parted
22	Ensure nodev option set on /var partition	mount
23	Ensure nosuid option set on /var partition	mount
24	Ensure separate partition exists for /var/tmp	parted
25	Ensure nodev option set on /var/tmp partition	mount
26	Ensure nosuid option set on /var/tmp partition	mount
27	Ensure noexec option set on /var/tmp partition	mount
28	Ensure separate partition exists for /var/log	parted
29	Ensure nodev option set on /var/log partition	mount
30	Ensure nosuid option set on /var/log partition	mount
31	Ensure noexec option set on /var/log partition	mount
32	Ensure separate partition exists for /var/log/audit	parted

STT	Tên khuyến nghị	Module
33	Ensure nodev option set on /var/log/audit partition	mount
34	Ensure nosuid option set on /var/log/audit partition	mount
35	Ensure noexec option set on /var/log/audit partition	mount
36	Ensure AppArmor is installed	apt
37	Ensure AppArmor is enabled in the bootloader configuration	lineinfile
38	Ensure all AppArmor Profiles are in enforce or complain mode	command
39	Ensure all AppArmor Profiles are enforcing	command
40	Ensure bootloader password is set	lineinfile
41	Ensure access to bootloader config is configured	file
42	Ensure address space layout randomization is enabled	sysctl
43	Ensure ptrace_scope is restricted	sysctl
44	Ensure core dumps are restricted	sysctl
45	Ensure prelink is not installed	apt
46	Ensure Automatic Error Reporting is not enabled	lineinfile
47	Ensure message of the day is configured properly	copy
48	Ensure local login warning banner is configured properly	copy
49	Ensure remote login warning banner is configured properly	copy
50	Ensure access to /etc/motd is configured	file
51	Ensure access to /etc/issue is configured	file
52	Ensure access to /etc/issue.net is configured	file
53	Ensure GDM is removed	apt
54	Ensure GDM login banner is configured	lineinfile
55	Ensure GDM disable-user-list option is enabled	lineinfile
56	Ensure GDM screen locks when the user is idle	lineinfile
57	Ensure GDM screen locks cannot be overridden	lineinfile
58	Ensure GDM automatic mounting of removable media is disabled	lineinfile
59	Ensure GDM disabling automatic mounting of removable media is not overridden	lineinfile
60	Ensure GDM autorun-never is enabled	lineinfile
61	Ensure GDM autorun-never is not overridden	lineinfile
62	Ensure XDMCP is not enabled	lineinfile
63	Ensure autofs services are not in use	service
64	Ensure avahi daemon services are not in use	service

STT	Tên khuyến nghị	Module
65	Ensure dhcp server services are not in use	service
66	Ensure dns server services are not in use	service
67	Ensure dnsmasq services are not in use	service
68	Ensure ftp server services are not in use	service
69	Ensure ldap server services are not in use	service
70	Ensure message access server services are not in use	service
71	Ensure network file system services are not in use	service
72	Ensure nis server services are not in use	service
73	Ensure print server services are not in use	service
74	Ensure rpcbind services are not in use	service
75	Ensure rsync services are not in use	service
76	Ensure samba file server services are not in use	service
77	Ensure snmp services are not in use	service
78	Ensure tftp server services are not in use	service
79	Ensure web proxy server services are not in use	service
80	Ensure web server services are not in use	service
81	Ensure xinetd services are not in use	service
82	Ensure X window server services are not in use	service
83	Ensure mail transfer agent is configured for local-only mode	lineinfile
84	Ensure NIS Client is not installed	apt
85	Ensure rsh client is not installed	apt
86	Ensure talk client is not installed	apt
87	Ensure telnet client is not installed	apt
88	Ensure ldap client is not installed	apt
89	Ensure ftp client is not installed	apt
90	Ensure a single time synchronization daemon is in use	service
91	Ensure systemd-timesyncd configured with authorized timeserver	lineinfile
92	Ensure systemd-timesyncd is enabled and running	service
93	Ensure chrony is configured with authorized timeserver	lineinfile
94	Ensure chrony is running as user _chrony	user
95	Ensure chrony is enabled and running	service
96	Ensure cron daemon is enabled and active	service

STT	Tên khuyến nghị	Module
97	Ensure permissions on /etc/crontab are configured	file
98	Ensure permissions on /etc/cron.hourly are configured	file
99	Ensure permissions on /etc/cron.daily are configured	file
100	Ensure permissions on /etc/cron.weekly are configured	file
101	Ensure permissions on /etc/cron.monthly are configured	file
102	Ensure permissions on /etc/cron.d are configured	file
103	Ensure crontab is restricted to authorized users	file
104	Ensure at is restricted to authorized users	file
105	Ensure wireless interfaces are disabled	service
106	Ensure bluetooth services are not in use	service
107	Ensure dccp kernel module is not available	modprobe
108	Ensure tipc kernel module is not available	modprobe
109	Ensure rds kernel module is not available	modprobe
110	Ensure sctp kernel module is not available	modprobe
111	Ensure ip forwarding is disabled	sysctl
112	Ensure packet redirect sending is disabled	sysctl
113	Ensure bogus icmp responses are ignored	sysctl
114	Ensure broadcast icmp requests are ignored	sysctl
115	Ensure icmp redirects are not accepted	sysctl
116	Ensure secure icmp redirects are not accepted	sysctl
117	Ensure reverse path filtering is enabled	sysctl
118	Ensure source routed packets are not accepted	sysctl
119	Ensure suspicious packets are logged	sysctl
120	Ensure tcp syn cookies is enabled	sysctl
121	Ensure ipv6 router advertisements are not accepted	sysctl
122	Ensure a single firewall configuration utility is in use	apt
123	Ensure ufw is installed	apt
124	Ensure iptables-persistent is not installed with ufw	apt
125	Ensure ufw service is enabled	service
126	Ensure ufw loopback traffic is configured	ufw
127	Ensure ufw firewall rules exist for all open ports	ufw
128	Ensure ufw default deny firewall policy	ufw

STT	Tên khuyến nghị	Module
129	Ensure nftables is installed	apt
130	Ensure ufw is uninstalled or disabled with nftables	service
131	Ensure a nftables table exists	nftables
132	Ensure nftables base chains exist	nftables
133	Ensure nftables loopback traffic is configured	nftables
134	Ensure nftables default deny firewall policy	nftables
135	Ensure nftables service is enabled	service
136	Ensure nftables rules are permanent	copy
137	Ensure iptables packages are installed	apt
138	Ensure nftables is not in use with iptables	service
139	Ensure ufw is not in use with iptables	service
140	Ensure iptables default deny firewall policy	iptables
141	Ensure iptables loopback traffic is configured	iptables
142	Ensure iptables firewall rules exist for all open ports	iptables
143	Ensure ip6tables default deny firewall policy	iptables
144	Ensure ip6tables loopback traffic is configured	iptables
145	Ensure ip6tables firewall rules exist for all open ports	iptables
146	Ensure permissions on /etc/ssh/sshd_config are configured	file
147	Ensure permissions on SSH private host key files are configured	file
148	Ensure permissions on SSH public host key files are configured	file
149	Ensure sshd access is configured	lineinfile
150	Ensure sshd Banner is configured	lineinfile
151	Ensure sshd Ciphers are configured	lineinfile
152	Ensure sshd ClientAliveInterval and ClientAliveCountMax are configured	lineinfile
153	Ensure sshd DisableForwarding is enabled	lineinfile
154	Ensure sshd GSSAPIAuthentication is disabled	lineinfile
155	Ensure sshd HostbasedAuthentication is disabled	lineinfile
156	Ensure sshd IgnoreRhosts is enabled	lineinfile
157	Ensure sshd KexAlgorithms is configured	lineinfile
158	Ensure sshd LoginGraceTime is configured	lineinfile
159	Ensure sshd LogLevel is configured	lineinfile
160	Ensure sshd MACs are configured	lineinfile

STT	Tên khuyến nghị	Module
161	Ensure sshd MaxAuthTries is configured	lineinfile
162	Ensure sshd MaxSessions is configured	lineinfile
163	Ensure sshd MaxStartups is configured	lineinfile
164	Ensure sshd PermitEmptyPasswords is disabled	lineinfile
165	Ensure sshd PermitRootLogin is disabled	lineinfile
166	Ensure sshd PermitUserEnvironment is disabled	lineinfile
167	Ensure sshd UsePAM is enabled	lineinfile
168	Ensure sudo is installed	apt
169	Ensure sudo commands use pty	lineinfile
170	Ensure sudo log file exists	file
171	Ensure users must provide password for privilege escalation	lineinfile
172	Ensure re-authentication for privilege escalation is not disabled globally	lineinfile
173	Ensure sudo authentication timeout is configured correctly	lineinfile
174	Ensure access to the su command is restricted	lineinfile
175	Ensure latest version of pam is installed	apt
176	Ensure libpam-modules is installed	apt
177	Ensure libpam-pwquality is installed	apt
178	Ensure pam_unix module is enabled	lineinfile
179	Ensure pam_faillock module is enabled	lineinfile
180	Ensure pam_pwquality module is enabled	lineinfile
181	Ensure pam_pwhistory module is enabled	lineinfile
182	Ensure password failed attempts lockout is configured	lineinfile
183	Ensure password unlock time is configured	lineinfile
184	Ensure password failed attempts lockout includes root account	lineinfile
185	Ensure password number of changed characters is configured	lineinfile
186	Ensure minimum password length is configured	lineinfile
187	Ensure password same consecutive characters is configured	lineinfile
188	Ensure password maximum sequential characters is configured	lineinfile
189	Ensure password dictionary check is enabled	lineinfile
190	Ensure password quality checking is enforced	lineinfile
191	Ensure password quality is enforced for the root user	lineinfile
192	Ensure password history remember is configured	lineinfile

STT	Tên khuyến nghị	Module
193	Ensure password history is enforced for the root user	lineinfile
194	Ensure pam_pwhistory includes use_authok	lineinfile
195	Ensure pam_unix does not include nullok	lineinfile
196	Ensure pam_unix does not include remember	lineinfile
197	Ensure pam_unix includes a strong password hashing algorithm	lineinfile
198	Ensure pam_unix includes use_authok	lineinfile
199	Ensure password expiration is configured	lineinfile
200	Ensure password expiration warning days is configured	lineinfile
201	Ensure strong password hashing algorithm is configured	lineinfile
202	Ensure inactive password lock is configured	lineinfile
203	Ensure all users last password change date is in the past	lineinfile
204	Ensure root is the only UID 0 account	lineinfile
205	Ensure root is the only GID 0 account	lineinfile
206	Ensure group root is the only GID 0 group	lineinfile
207	Ensure root account access is controlled	lineinfile
208	Ensure root path integrity	lineinfile
209	Ensure root user umask is configured	lineinfile
210	Ensure system accounts do not have a valid login shell	lineinfile
211	Ensure accounts without a valid login shell are locked	lineinfile
212	Ensure nologin is not listed in /etc/shells	lineinfile
213	Ensure default user shell timeout is configured	lineinfile
214	Ensure default user umask is configured	lineinfile
215	Ensure journald service is enabled and active	service
216	Ensure only one logging system is in use	service
217	Ensure systemd-journal-remote is installed	apt
218	Ensure systemd-journal-upload is enabled and active	service
219	Ensure systemd-journal-remote service is not in use	service
220	Ensure journald ForwardToSyslog is disabled	lineinfile
221	Ensure journald Compress is configured	lineinfile
222	Ensure journald Storage is configured	lineinfile
223	Ensure rsyslog is installed	apt
224	Ensure rsyslog service is enabled and active	service

STT	Tên khuyến nghị	Module
225	Ensure journald is configured to send logs to rsyslog	lineinfile
226	Ensure rsyslog log file creation mode is configured	lineinfile
227	Ensure rsyslog is not configured to receive logs from a remote client	lineinfile
228	Ensure access to all logfiles has been configured	lineinfile
229	Ensure auditd packages are installed	apt
230	Ensure auditd service is enabled and active	service
231	Ensure auditing for processes that start prior to auditd is enabled	lineinfile
232	Ensure audit_backlog_limit is sufficient	sysctl
233	Ensure audit log storage size is configured	lineinfile
234	Ensure audit logs are not automatically deleted	lineinfile
235	Ensure system is disabled when audit logs are full	lineinfile
236	Ensure system warns when audit logs are low on space	lineinfile
237	Ensure changes to system administration scope (sudoers) is collected	lineinfile
238	Ensure actions as another user are always logged	lineinfile
239	Ensure events that modify the sudo log file are collected	lineinfile
240	Ensure events that modify date and time information are collected	lineinfile
241	Ensure events that modify the system's network environment are collected	lineinfile
242	Ensure use of privileged commands are collected	lineinfile
243	Ensure unsuccessful file access attempts are collected	lineinfile
244	Ensure events that modify user/group information are collected	lineinfile
245	Ensure discretionary access control permission modification events are collected	lineinfile
246	Ensure successful file system mounts are collected	lineinfile
247	Ensure session initiation information is collected	lineinfile
248	Ensure login and logout events are collected	lineinfile
249	Ensure file deletion events by users are collected	lineinfile
250	Ensure events that modify the system's Mandatory Access Controls are collected	lineinfile
251	Ensure successful and unsuccessful attempts to use the chcon command are collected	lineinfile
252	Ensure successful and unsuccessful attempts to use the setfacl command are collected	lineinfile
253	Ensure successful and unsuccessful attempts to use the chacl command are collected	lineinfile
254	Ensure successful and unsuccessful attempts to use the usermod command are collected	lineinfile
255	Ensure kernel module loading unloading and modification is collected	lineinfile

STT	Tên khuyến nghị	Module
256	Ensure the audit configuration is immutable	lineinfile
257	Ensure audit log files mode is configured	file
258	Ensure audit log files owner is configured	file
259	Ensure audit log files group owner is configured	file
260	Ensure the audit log file directory mode is configured	file
261	Ensure audit configuration files mode is configured	file
262	Ensure audit configuration files owner is configured	file
263	Ensure audit configuration files group owner is configured	file
264	Ensure audit tools mode is configured	file
265	Ensure audit tools owner is configured	file
266	Ensure audit tools group owner is configured	file
267	Ensure AIDE is installed	apt
268	Ensure filesystem integrity is regularly checked	service
269	Ensure cryptographic mechanisms are used to protect the integrity of audit tools	lineinfile
270	Ensure permissions on /etc/passwd are configured	file
271	Ensure permissions on /etc/passwd- are configured	file
272	Ensure permissions on /etc/group are configured	file
273	Ensure permissions on /etc/group- are configured	file
274	Ensure permissions on /etc/shadow are configured	file
275	Ensure permissions on /etc/shadow- are configured	file
276	Ensure permissions on /etc/gshadow are configured	file
277	Ensure permissions on /etc/gshadow- are configured	file
278	Ensure permissions on /etc/shells are configured	file
279	Ensure permissions on /etc/security/opasswd are configured	file
280	Ensure world writable files and directories are secured	command
281	Ensure no files or directories without an owner and a group exist	command
282	Ensure accounts in /etc/passwd use shadowed passwords	lineinfile
283	Ensure /etc/shadow password fields are not empty	lineinfile
284	Ensure all groups in /etc/passwd exist in /etc/group	lineinfile
285	Ensure shadow group is empty	lineinfile
286	Ensure no duplicate UIDs exist	lineinfile
287	Ensure no duplicate GIDs exist	lineinfile

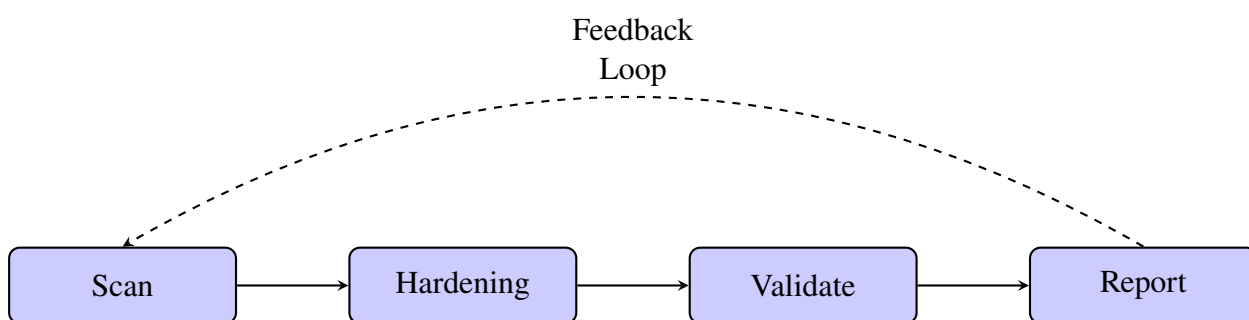
STT	Tên khuyến nghị	Module
288	Ensure no duplicate user names exist	lineinfile
289	Ensure no duplicate group names exist	lineinfile
290	Ensure local interactive user home directories are configured	lineinfile
291	Ensure local interactive user dot files access is configured	lineinfile

Bảng 1.2: Danh sách các khuyến nghị CIS có thể tự động hóa

Chương 2

Phương pháp triển khai

2.1 Quy trình tổng thể



Hình 2.1: Quy trình 4 bước triển khai bảo mật hệ thống

Quy trình triển khai bảo mật được thiết kế theo chu trình 4 bước chính, đảm bảo tính toàn diện và có thể lặp lại. Mỗi bước có vai trò cụ thể và liên kết chặt chẽ với nhau để tạo ra một hệ thống bảo mật hoàn chỉnh.

Quy trình này bắt đầu từ việc đánh giá trạng thái hiện tại, tiếp theo là áp dụng các biện pháp hardening, sau đó xác thực kết quả và cuối cùng là tạo báo cáo chi tiết. Vòng lặp này giúp đảm bảo hệ thống luôn được cập nhật và tuân thủ các tiêu chuẩn bảo mật mới nhất.

2.2 Phương pháp tiếp cận

2.2.1 Manual Configuration

Cấu hình thủ công là phương pháp truyền thống trong quản trị hệ thống. Administrator trực tiếp thực hiện các thay đổi trên hệ thống thông qua command line, giao diện đồ họa hoặc file config.

Các công cụ sử dụng trong cấu hình thủ công:

- **Command Line Tools:** ansible-playbook, systemctl, ufw, iptables, nftables, chmod, chown, mount, netstat, lynis, aide, auditd, fail2ban

- **Giao diện đồ họa (GUI):** AWX/Tower, Grafana, Webmin, Cockpit
- **File cấu hình:** `/etc/sysctl.conf`, `/etc/fstab`, `/etc/ssh/sshd_config`, `/etc/network/interfaces`, `/etc/passwd`, `/etc/shadow`, `ansible.cfg`, `inventory/hosts`, `playbooks/`

Phương pháp này có ưu điểm là linh hoạt và dễ kiểm soát từng bước, nhưng nhược điểm lớn là tốn nhiều thời gian, dễ xảy ra sai sót, và khó đảm bảo tính nhất quán giữa nhiều hệ thống khác nhau.

Đối với các hệ thống quy mô nhỏ, cấu hình thủ công vẫn có thể được áp dụng cho các tác vụ đặc thù yêu cầu sự can thiệp chuyên sâu.

2.2.2 Automation bằng Ansible

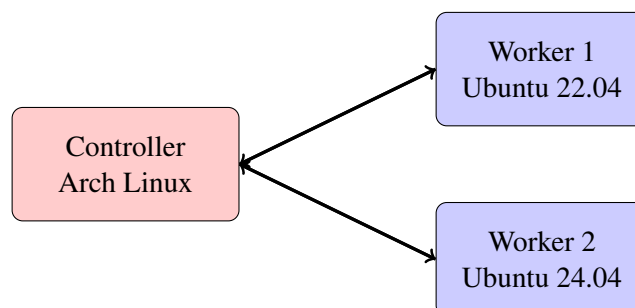
Ansible là công cụ tự động hóa mạnh mẽ giúp loại bỏ các thao tác thủ công lặp đi lặp lại. Với Ansible, chúng ta có thể định nghĩa toàn bộ quy trình hardening dưới dạng code, đảm bảo tính nhất quán và có thể tái sử dụng.

Các công cụ sử dụng trong automation bằng Ansible:

- **Ansible Command Line Tools:** `ansible-playbook`, `ansible-inventory`, `ansible-vault`, `ansible-galaxy`, `ansible-pull`
- **Ansible GUI Tools:** AWX/Tower, Ansible Semaphore, Rundeck, Jenkins với Ansible plugin
- **Ansible Configuration Files:** `ansible.cfg`, `inventory/hosts`, `playbooks/*.yaml`, `roles/*/tasks/main.yaml`, `group_vars/*`, `host_vars/*`, `vars/*`, `vault/*`

Ansible sử dụng YAML để định nghĩa các playbook, giúp administrator dễ dàng đọc, hiểu và chỉnh sửa. Khả năng idempotent của Ansible đảm bảo rằng việc chạy nhiều lần sẽ không gây ra các trạng thái không mong muốn.

2.3 Mô hình triển khai



Hình 2.1: Mô hình triển khai Controller-Workers

Hệ thống được triển khai theo mô hình Controller–Workers, trong đó một máy trung tâm (Controller) chịu trách nhiệm điều phối và quản lý cấu hình, trong khi các máy Worker đóng vai trò là các node mục tiêu được cấu hình tự động.

Cụ thể trong đề tài:

- **Controller:** Arch Linux (chạy Ansible)
- **Worker 1:** Ubuntu 22.04
- **Worker 2:** Ubuntu 24.04

Mô hình này cho phép thực hiện quản lý tập trung, đảm bảo tính nhất quán và giảm thiểu sai sót trong quá trình cấu hình hệ thống.

2.3.1 Quy trình triển khai

Quy trình triển khai hệ thống được thực hiện theo hướng tự động hóa thông qua Ansible, bao gồm các bước chính sau:

1. Chuẩn bị môi trường

- Máy Controller được cài đặt Ansible và các công cụ cần thiết
- Các Worker Nodes được cài đặt SSH server và Python để hỗ trợ thực thi từ xa

2. Thiết lập kết nối SSH

- Cơ chế xác thực bằng SSH key được sử dụng để đảm bảo kết nối an toàn
- Không cần nhập mật khẩu giữa Controller và các Worker

3. Cấu hình Inventory

- Danh sách các Worker Nodes được khai báo trong file inventory
- Bao gồm địa chỉ IP, user và thông tin xác thực

4. Triển khai cấu hình tự động

- Các playbook Ansible được sử dụng để thực hiện cấu hình hệ thống
- Áp dụng tiêu chuẩn CIS Benchmark trên toàn bộ các Worker

5. Kiểm tra và đánh giá

- Sau khi triển khai, hệ thống được kiểm tra lại thông qua các công cụ audit
- Đánh giá mức độ tuân thủ bảo mật

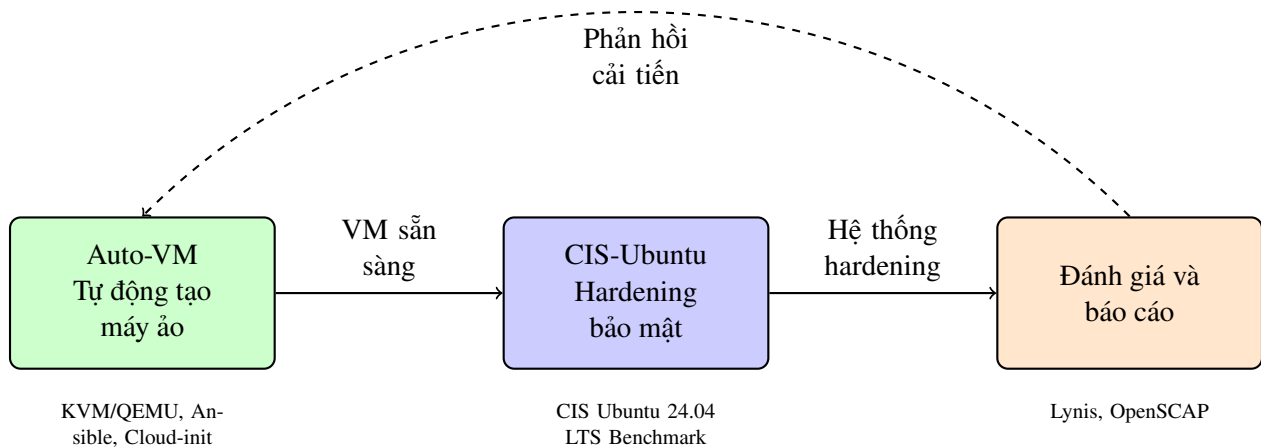
6. Bảo trì hệ thống

- Hệ thống được duy trì thông qua việc audit định kỳ
- Cập nhật playbook và giám sát log để phát hiện sớm các vấn đề

Quy trình này giúp đảm bảo việc triển khai hệ thống diễn ra nhất quán, có thể lặp lại và dễ dàng mở rộng.

2.3.2 Mô hình triển khai Automated Security Hardening System

Dựa trên mô hình Controller–Workers, hệ thống Automated Security Hardening System được mở rộng thành kiến trúc tích hợp gồm ba thành phần chính:



Hình 2.2: Mô hình triển khai Automated Security Hardening System với chu trình khép kín

1. Auto-VM – Tạo máy ảo tự động

Thành phần này chịu trách nhiệm tự động hóa quá trình tạo và cấu hình máy ảo.

Công nghệ: KVM/QEMU, Ansible, Cloud-init

Chức năng:

- Tạo VM từ Ubuntu cloud image
- Tự động cấu hình user, SSH key
- Gán IP và cập nhật vào inventory

Đầu ra là các máy ảo sẵn sàng cho việc triển khai tiếp theo.

2. CIS-Ubuntu – Hardening bảo mật

Thành phần này thực hiện triển khai tiêu chuẩn CIS Ubuntu 24.04 LTS Benchmark v1.0.0.

Hệ thống được chia thành 7 giai đoạn:

- Initial Setup
- Services
- Network
- Firewall
- Access Control

- Logging
- Maintenance

Mỗi giai đoạn được triển khai dưới dạng Ansible roles, đảm bảo:

- Tính modular
- Khả năng tái sử dụng
- Idempotent (chạy lại không gây lỗi)

3. Báo cáo và đánh giá

Thành phần này thực hiện đánh giá mức độ bảo mật của hệ thống sau khi hardening.

Công cụ: Lynis, OpenSCAP

Đầu ra:

- Báo cáo HTML
- Điểm compliance
- Danh sách lỗ hổng và khuyến nghị

Quy trình hoạt động tổng thể

Hệ thống hoạt động theo chu trình khép kín:

- Tạo máy ảo bằng Auto-VM
- Triển khai hardening bằng CIS-Ubuntu
- Đánh giá bằng Lynis và OpenSCAP
- Phản hồi kết quả để cải tiến hệ thống

Ưu điểm của mô hình

- Tự động hóa toàn bộ quy trình
- Đảm bảo tính nhất quán giữa các hệ thống
- Dễ dàng mở rộng quy mô
- Hỗ trợ kiểm soát phiên bản thông qua Git
- Tích hợp cơ chế phản hồi (feedback loop)

Chương 3

Triển khai

Chương 4

Tổng kết

4.1 Kết quả đạt được

4.2 Hạn chế

4.3 Hướng phát triển